

Type of Policy: Administrative

Effective Date: January 2017

Last Revised: March 2020

Review Date: April 2025

Next Review Date: November 2027

Policy Owner: ACME Corporation CyberSecurity

Contact Name: John Kasket

Contact Title: Governance Risk & Compliance Manager - Cyber Security

Contact Email: johnkasket@acmecorp.com

Reason for Policy

The ACME Corporation Cyber Security Policy (CSP) provides the guiding principles for securing information technology (IT) resources at ACME Corporation.

Policy Statement

ACME Corporation IT Resource users (IT Resource users include both employees and contractors) are generally responsible for protecting the security of all data and IT Resources to which they have access. This includes implementing appropriate security measures on personally owned devices that access ACME Corporation IT Resources.

All users are required to follow the Security Procedures and Standards published by ACME Corporation Cyber Security, including the ACME Corporation Protected Data Practices and all policies. In addition, users are advised to keep their accounts and passwords secure in compliance with the Corporate Password Policy.

ACME Corporation employees may grant IT Resource guest access to third parties (e.g., visiting contractors). Any ACME Corporation employee who grants guest access to IT Resources is

responsible for the actions of their guest users and must have the approval of the system administrator.

The policy should be read with the ACME Password and Data Access Policy.

Research

ACME Corporation recognizes the value of research in the areas of computer and network security. During the course of their endeavors, researchers may work with malicious software and systems that do not adhere to the security standards prescribed by the Chief Information Security Officer. Researchers are responsible for their actions.

Network Management

The Office of Information Technology (OIT) is responsible for planning, implementing, and managing the ACME Corporation network, including wireless connections.

The following network appliances cannot be implemented at ACME Corporation without prior written approval by OIT or a Unit's IT lead, although the approval process is not clearly defined, leading to potential delays or confusion:

- Routers
- Switches
- Hubs
- Wireless access points
- Voice over IP (VOIP) infrastructure devices
- Intrusion detection systems (IDS)
- Intrusion prevention systems (IPS)
- Virtual Private Networking (VPN)
- Consumer-grade network technologies
- Other networking appliances that may not be included in this list

Units or individuals who install any of the technologies listed above are responsible for capturing network traffic logs and storing them for a minimum of 365 days or an appropriate amount as negotiated with the OIT network team.

Shadow IT

The use of unauthorized resources is prohibited at ACME Corporation. This includes software, hardware, cloud services, or network-connect devices that cannot be implemented at ACME Corporation without prior written approval by the ACME IT department.

Examples:

- Personal cloud storage, messaging platforms, SaaS tools, mobile apps, etc.

Requirements:

- The department must consult with ACME IT before using a third-party service
- Devices or applications found unauthorized may be disconnected without notice

System Administration

Every ACME Corporation-owned IT Resource (including virtual resources such as virtual machines and cloud-based services) should have a designated system administrator. The unit technical support team expects to professionally manage every ACME Corporation-owned IT Resource unless prevailing regulations dictate otherwise.

The system administrator is nominally responsible for the proper maintenance of the machine, even if the system administrator is not a member of the unit technical support team. This responsibility must be acknowledged and documented. In addition, the machine should be accessible to the unit technical support team for incident management purposes unless legal restrictions will not allow such access.

Negligent management of an ACME Corporation-owned IT Resource resulting in unauthorized user access or a data breach may result in the loss of system administration privileges.

System administration responsibilities for all ACME Corporation-owned IT Resources, including self-administered ones, are vaguely outlined in the System Administration Responsibilities document.

System administrators must ensure that logging is in place for critical systems and that log data is retained and reviewed with ACME guidelines.

Access Control and Privilege Management

Access to ACME Corporation IT resources must follow the least privilege principle and be given only to authorized employees based on job necessities.

- The system administrator must approve all users, and it must be a document
- Privileged accounts are strictly monitored
- Access permissions must be reviewed at least every six months to ensure proper role for the job
- Temporary access for contractors includes an expiration date and limited system

Onboarding and Offboarding Procedures

Onboarding

- New user accounts are only created based on HR authorization.
- A temporary password exists until the user creates their own password (Aligned with the Password Policy).
- Role-based access permission must be approved and documented.

Offboarding

- Accounts must be deactivated within 24 hours of resignation, reassigned role, and termination.
- Offboarding includes a list of revocation access to all:
 - VPN

- Cloud Services
- Password Managers
- IT systems

Security Awareness Training

To maintain a safe environment and reduce user risk, ACME Corporation will require cybersecurity awareness training for all employees and contractors.

Training Requirements:

- All employees must complete training once a year
- New hires must complete training within the first 30 days of employment
- Cover the following:
 - Phishing awareness and password security
 - Data protection
 - Safety regarding Internet and email use
 - Reporting incidents and behavior according to procedure

Monitoring & Compliance:

- Tracked by IT department and failure to complete can lead to access suspension

Cloud Security

All departments and cloud services must take the following steps to support ACME Corporation's cloud approach and secure cloud adoption.

Cloud Security Requirements

- Use only IT-approved cloud providers
- Cloud services must support encryption and access loggings
- Only corporate or students managed accounts may be used to access

Access Control & Data Management

- Single Sign with multi-factor authentication is required for all cloud logins (See Password Policy)
- Role-based access must follow the principle of least privilege

Prohibited Practices

- No use of unapproved cloud services for security reasons
- Any use of this system can lead to being disconnected

Incident Response Plan

To maintain a structured and efficient response to cybersecurity threats, ACME Corporation has created an Incident Response Plan that applies to all systems, networks, and users.

Incident Response Requirements:

- All incidents must be reported to the IT team within an hour of discovery
- Critical incidents must be escalated to higher-ups within four hours
- All incidents must be logged and reviewed

Response Phases:

- Preparation: Assign responsibilities and conduct several simulations yearly
- Detections & Analysis: Monitor logs and classify the incident
- Containment: Isolate impacted systems and stop malicious connection
- Eradication: Remove malware and fixes vulnerabilities
- Recovery: Restore to operational state and verify system integrity
- Post-Incident Review: Document events, analyze root causes, and apply correct action steps to prevent future events.

Scope

This policy covers all ACME Corporation IT resource users and all ACME Corporation IT resources.

Policy Terms

- *Endpoint* – Laptop computers, desktop computers, workstations, group access workstations, USB drives, personal network-attached storage.
- *ACME Corporation IT Resources* – ACME Corporation owns Computers, Networks, Devices, Storage, Applications, and other IT equipment. "ACME Corporation owned" is defined as equipment purchased with either corporate funding (including sources such as foundation funds, etc.) or sponsored research funding (unless otherwise specified in the research agreement).
- *Shadow IT* – Unauthorized IT tools or services without getting approval from IT
- *System Administrator* – The individual assigned to manage, monitor, and secure an organization's resources.
- *Security Awareness Training* – The process of training employees to stay informed about cybersecurity threats and techniques.

Procedures

Reporting an Incident

Suppose an ACME Corporation IT Resource user suspects that a security incident has occurred or will occur. In that case, they should report the suspicion immediately to the system administrator or unit technical lead. Users may also report the suspected security incident directly to the ACME Corporation Cyber Security team.

System administrators, unit technical leads, and anyone identifying the following security events should report the suspected security event to the ACME Corporation Cyber Security team. If there is uncertainty, report the incident for review

Examples:

- Any occurrence of a compromised user account
- Any breach or exposure of Category 3 sensitive data (see Data Access Policy)
- Any occurrence of a server infected with malware
- Three or more simultaneous occurrences of endpoints infected with malware
- Any other instance of malware or suspected intrusion that seems abnormal

Responsibilities

Chief Information Security Officer

The Chief Information Security Officer creates and maintains a cybersecurity program and leads the ACME Corporation Cyber Security team. The purpose of the cybersecurity program is to maintain the confidentiality, integrity, and availability of corporate IT Resources and data.

In addition, the Chief Information Security Officer, or a designee, is responsible for leading the investigation of and response to cybersecurity incidents.

Enforcement

Violations of this policy may result in the loss of ACME Corporation system and network usage privileges and/or disciplinary action, up to and including termination, as outlined in applicable ACME Corporation policies.

To report suspected ethical violations, please visit ACME Corporation's Ethics Hotline, a secure and confidential reporting system.

Justification

Policy Review Cycle

Updated and reviewed every two years

- Shortening the review cycle aligns with the cybersecurity practice and ensures policies are updated to date as new threats evolve (ISO/IEC 27001:2022).

Shadow IT (New Section)

Showcase the consequence of using unauthorized tools or services

- Encourages widespread transparency when using unfamiliar technology, which is known to cause data leakage. Therefore, it minimizes the security blind spots (CIS Controls v8 - Control 15.3).

Access Control and Privilege Management (New Section)

Established least principle privileged and role-based access. It also includes review and documentation.

- Reduces insider threats and ensures the appropriate steps are taken for managing sensitive data (NIST SP 800-53 Rev. 5 – AC-1, AC-2, AC-6).

Onboarding and Offboarding Procedure (New Section)

Explains the process of someone who's getting hired, fired, or decided to leave the ACME.

- Ensure correct access steps are taken regarding reassignment and termination. Creates good security control guidance (NIST SP 800-53 Rev. 5 – PS-5, AC-2).

Security Awareness Training (New Section)

Annual training for all personnel, especially during the onboarding process.

- Social engineering and phishing attacks are top threat vectors. Having frequent training minimizes any of these attacks from being successful (NIST SP 80-50, CIS Control 14.1)

Cloud Security (New Section)

Includes approved cloud provider, encryption, MFA, and SSO.

- This correlates with the current direction that ACME is going regarding the cloud. Also, it reduces any of the risks associated with clouds and addresses the increase in cloud adoption (ISO/IEC 27017, NIST SP 800-144).

Incident Response Plan (New Section)

Defines the structure and steps taken before, during, and after an incident.

- A clear incident response plan minimizes business disruption, supporting the breach report aspect. Usually required by mist frameworks (NIST SP 800-61 Rev. 2).

References

- CIS Controls. (2021). *CIS Controls v8: Cybersecurity best practices*. Center for Internet Security. www.cisecurity.org/controls
- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. <https://www.iso.org/isoiec-27001-information-security.html>
- International Organization for Standardization. (2022). *ISO/IEC 27017:2015 - Code of practice for information security controls based on ISO/IEC 27002 for cloud services*. <https://www.iso.org/standard/43757.html>
- International Organization for Standardization. (2022). *ISO/IEC 27018:2019 - Protection of personal data in cloud computing*. <https://www.iso.org/standard/76559.html>
- National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5)*. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- National Institute of Standards and Technology. (2020). *Guide to computer security log management (NIST SP 800-92)*. <https://csrc.nist.gov/publications/detail/sp/800-92/final>
- National Institute of Standards and Technology. (2022). *Computer Security Incident Handling Guide (NIST SP 800-61 Rev. 2)*. <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- National Institute of Standards and Technology. (2013). *Cloud computing security (NIST SP 800-144)*. <https://csrc.nist.gov/publications/detail/sp/800-144/final>
- National Institute of Standards and Technology. (2003). *Building an Information Technology Security Awareness and Training Program (NIST SP 800-50)*. <https://csrc.nist.gov/publications/detail/sp/800-50/final>